FortySeven-1

20 April 2026 18:48

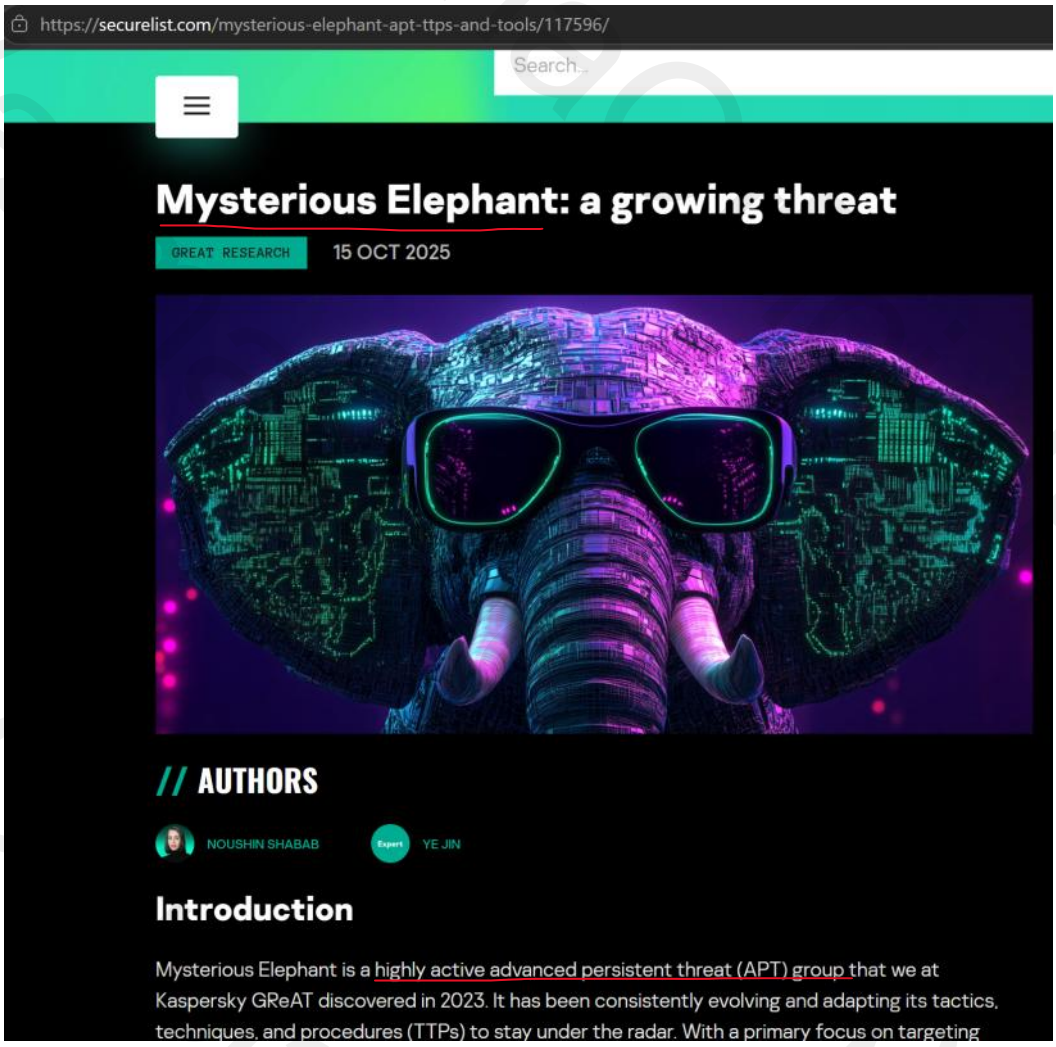
NOTE: This HTB Sherlock has been done independently. The resources are given in the HTB Sherlock page.

Category: Threat Intelligence

Evidence - 1 - https://securelist.com/mysterious-elephant-apt-ttps-and-tools/117596/
Evidence - 2 - https://medium.com/@knownsec404team/apt-k-47-mysterious-elephant-a-new-apt-organization-in-south-asia-5c66f954477
Evidence - 3 - https://medium.com/@knownsec404team/unveiling-the-past-and-present-of-apt-k-47-weapon-asyncshell-5a98f75c2d68

1. An APT group named `Mysterious Elephant` uses Hajj-themed phishing to lure the target and then steal WhatsApp data from Government and diplomatic officials.

This refers to the tactic known as `Spear Phishing`.



2. `Knownsec 404 Advanced Threat Intelligence` team, who was the first in the world to capture the APT team's weapon known as `ORPCBackdoor`.

According to the Intelligence team, the earliest attack activity they tracked started from March 2022.

medium.com/@knownsec404team/apt-k-47-mysterious-elephant-a-new-apt-organization-in-south-asia-5c66f954477

Search

At the same time, after backtracking analysis, we found that the earliest attack activities of the organization should start around March 2022. This article will publish the details of the APT group's attacks and the relevant IOCS.

3

- The APT team uses a custom backdoor that communicates via Office Remote Procedure Call (ORPCBackdoor). This backdoor has a total 17 export functions. But the two main malicious entries are `GetFileVersionInfoByHandleEx(void)` and `DllEntryPoint`.

ORPCBackdoor has a total of 17 export functions, and the relevant export function names are as follows:

```
GetFileVersionInfoA
GetFileVersionInfoByHandle
GetFileVersionInfoExW
GetFileVersionInfoSizeA
GetFileVersionInfoSizeExW
GetFileVersionInfoSizeW
GetFileVersionInfoW
VerFindFileA
VerFindFileW
VerInstallFileA
VerInstallFileW
VerLanguageNameA
VerLanguageNameW
VerQueryValueA
VerQueryValueW
GetFileVersionInfoByHandleEx(void)
DllEntryPoint
```

4. The backdoor first checks for a file - `ts.dat`, if it is in the same path. If it isn't it, then it performs task to create persistence. `ts.dat` is a data file associated with a software that uses Time Series (TS) information, which means it logs the data, which can help detect the backdoor.

@VarmaOfficialRepo

2. persistence

ORPCBackdoor determines whether the file exists to prevent multiple persistent creation. Before persistent creation, ORPCBackdoor determines whether the ts.dat file exists in the same path. If the file does not exist, ORPCBackdoor will create persistence. The TaskScheduler CLSID is invoked by COM,which name is Microsoft Update. After the task is created, the ts.dat file is created.

5. Next, the Intelligence team found a pattern in the backdoor that resembled to 'BITTER' tactics.

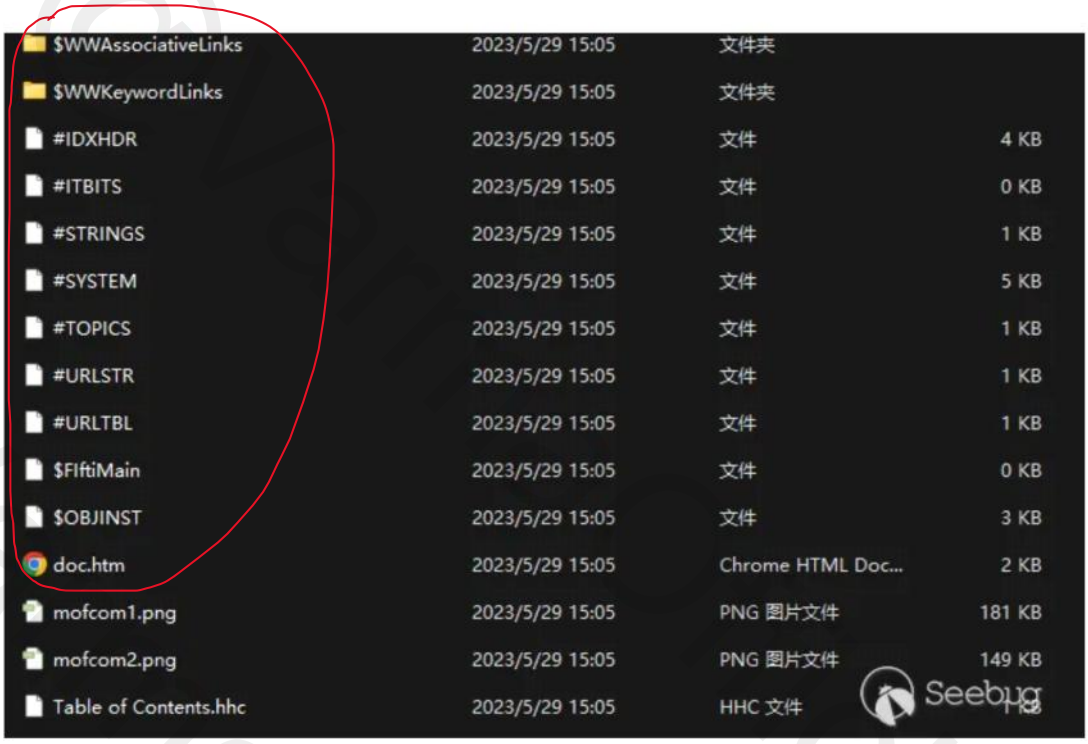
The CHM file structure used by BITTER in past attacks as follows:

$WWAssociativeLinks	2023/3/1 11:05	文件夹
$WWKeywordLinks	2023/3/1 11:05	文件夹
#IDXHDR	2023/3/1 11:05	文件
#ITBITS	2023/3/1 11:05	文件
#STRINGS	2023/3/1 11:05	文件
#SYSTEM	2023/3/1 11:05	文件
#TOPICS	2023/3/1 11:05	文件
#URLSTR	2023/3/1 11:05	文件
#URLTBL	2023/3/1 11:05	文件
$FIftiMain	2023/3/1 11:05	文件
$OBJINST	2023/3/1 11:05	文件
doc.htm	2023/3/1 11:05	Chrome HTML Document
Index.hhk	2023/3/1 11:05	HHK 文件
Table of Contents.hhc	2023/3/1 11:05	HHC 文件

Seebug

@VarmaOfficialRepo

The CHM file structure of the initial stage about ORPCBackdoor captured this time is as follows:



$WWAssociativeLinks	2023/5/29 15:05	文件夹	
$WWKeywordLinks	2023/5/29 15:05	文件夹	
#IDXHDR	2023/5/29 15:05	文件	4 KB
#ITBITS	2023/5/29 15:05	文件	0 KB
#STRINGS	2023/5/29 15:05	文件	1 KB
#SYSTEM	2023/5/29 15:05	文件	5 KB
#TOPICS	2023/5/29 15:05	文件	1 KB
#URLSTR	2023/5/29 15:05	文件	1 KB
#URLTBL	2023/5/29 15:05	文件	1 KB
$FIftiMain	2023/5/29 15:05	文件	0 KB
$OBJINST	2023/5/29 15:05	文件	3 KB
doc.htm	2023/5/29 15:05	Chrome HTML Doc...	2 KB
mofcom1.png	2023/5/29 15:05	PNG 图片文件	181 KB
mofcom2.png	2023/5/29 15:05	PNG 图片文件	149 KB
Table of Contents.hhc	2023/5/29 15:05	HHC 文件	

From the above images, we can see that overall structure is almost similar. But the ORPCBackdoor is improved version combining the other APT team's attack tools.

6. The intelligence team found that the APT team consistently updated the backdoor. In 2023, with C2 communication evolved from TCP to HTTPS and the tool was called `Asyncshell-v2`.

Version \ Difference item	Initial active	Communication protocol	log information	Loading method	How to obtain C2	Instruction type
v1	2023.9	TCP	√	CVE-2023-38831 CHM loading and execution	hardcoded	CMD Powershell
v2	2024.4	Https	√	CHM loading and execution disguised as PDF document	hardcoded	CMD
v3	2024.7	TCP	√	lnk+vbs	Decrypt files	CMD
v4	2024.9	Http TCP	×	CHM loading execution	Server-side distribution	CMD

7. One of the latest modules used by `Mysterious Elephant` and loaded by `BabShell` is `MemLoader HidenDesk`.

`MemLoader HidenDesk` is a reflective PE loader that loads and executes malicious payloads in memory. It uses encryption and decryption to evade detection.

MemLoader HidenDesk operates in the following manner:

1 The malware checks the number of active processes and terminates itself if there are fewer than 40 processes running — a technique used to evade sandbox analysis.

2 It creates a shortcut to its executable and saves it in the autostart folder, ensuring it can restart itself after a system reboot.

3 The malware then creates a hidden desktop named "MalwareTech_Hidden" and switches to it, providing a covert environment for its activities. This technique is borrowed from an open-source project on GitHub.

4 Using an RC4-like algorithm with the key [redacted], the malware decrypts a block of data from its own binary and executes it in memory as a shellcode. The shellcode's sole purpose is to load and execute a PE file, specifically a sample of the commercial RAT called "Remcos" (MD5: 037b2f6233ccc82f0c75bf56c47742bb).

From the image, `Memloader` first checks the number of active running processes. If it is fewer than 40 processes it terminates itself.

Then, a shortcut is created to the executable and saved to the 'autostart' folder. Next, a hidden desktop `MalwareTech_Hidden` is created, so a covert environment is created for the activities. The malware then decrypts a block of its own binary data to load & execute in memory.

8. From the above image, we can see that the shortcut of executable file added to 'autostart' folder is done by `Registry Run Keys / Startup Folder`. It is a technique recognised by MITRE ATT&CK Framework with the ID 'T1547.001'.

T1547	Boot or Logon Autostart Execution	Adversaries may configure system settings to automatically execute a program during system boot or logon to maintain persistence or gain higher-level privileges on compromised systems. Operating systems may have mechanisms for automatically running a program on system boot or account logon. These mechanisms may include automatically executing programs that are placed in specially designated directories or are referenced by repositories that store configuration information, such as the Windows Registry. An adversary may achieve the same goal by modifying or extending features of the kernel.
.001	Registry Run Keys / Startup Folder	Adversaries may achieve persistence by adding a program to a startup folder or referencing it with a Registry run key. Adding an entry to the "run keys" in the Registry or startup folder will cause the program referenced to be executed when a user logs in. These programs will be executed under the context of the user and will have the account's associated permissions level.

9. As mentioned in first point, the APT uses phishing tactic to get WhatsApp data. The APT team has made customized exfiltration modules called `Uplo Exfiltrator` and `Stom Exfiltrator`.

@VarmaOfficialRepo

- **Uplo Exfiltrator**

The Uplo Exfiltrator is a data exfiltration tool that targets specific file types and uploads them to the attackers' C2 servers. It uses a simple XOR decryption to deobfuscate C2 domain paths and employs a recursive depth-first directory traversal algorithm to identify valuable files. The malware specifically targets file types that are likely to contain potentially sensitive data, including documents, spreadsheets, presentations, archives, certificates, contacts, and images. The targeted file extensions include .TXT, .DOC, .DOCX, .PDF, .XLS, .XLSX, .CSV, .PPT, .PPTX, .ZIP, .RAR, .7Z, .PFX, .VCF, .JPG, .JPEG, and .AXX.

- **Stom Exfiltrator**

The Stom Exfiltrator is a commonly used exfiltration tool that recursively searches specific directories, including the "Desktop" and "Downloads" folders, as well as all drives except the C drive, to collect files with predefined extensions. Its latest variant is specifically designed to target files shared through the WhatsApp application. This version uses a hardcoded folder path to locate and exfiltrate such files:

10. The Intelligence team's analysis highlighted the threat actor's heavy use of scripts for executing and deploying payloads. This tactic also can be found in MITRE ATT&CK Framework with id 'T1059.001'.

T1059	Command and Scripting Interpreter	Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries. These interfaces and languages provide ways of interacting with computer systems and are a common feature across many different platforms. Most systems come with some built-in command-line interface and scripting capabilities, for example, macOS and Linux distributions include some flavor of Unix Shell while Windows installations include the Windows Command Shell and PowerShell.
.001	PowerShell	Adversaries may abuse PowerShell commands and scripts for execution. PowerShell is a powerful interactive command-line interface and scripting environment included in the Windows operating system. Adversaries can use PowerShell to perform a number of actions, including discovery of information and execution of code. Examples include the `Start-Process` cmdlet which can be used to run an executable and the `Invoke-Command` cmdlet which runs a command locally or on a remote computer (though administrator permissions are required to use PowerShell to connect to remote systems).

11. Another point in the analysis was that in January 2024 campaign of `Mysterious Elephant`, the team delivered an Asyncshell payload, which exploited the `CVE-2023-38831`.

@VarmaOfficialRepo

CVE-2023-38831 Detail

Description

RARLAB WinRAR before 6.23 allows attackers to execute arbitrary code when a user attempts to view a benign file within a ZIP archive. The issue occurs because a ZIP archive may include a benign file (such as an ordinary .JPG file) and also a folder that has the same name as the benign file, and the contents of the folder (which may include executable content) are processed during an attempt to access only the benign file. This was exploited in the wild in April through October 2023.

Metrics

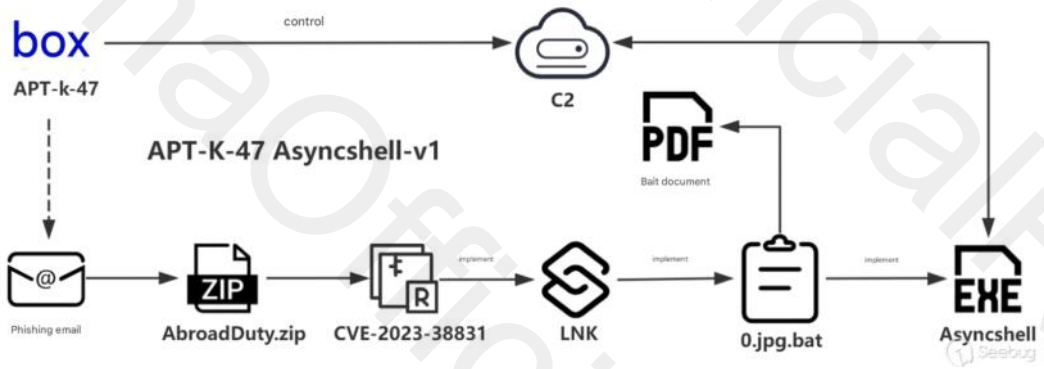
CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD	**Base Score:** 7.8 HIGH	**Vector:** CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
ADP: CISA-ADP	**Base Score:** 7.8 HIGH	**Vector:** CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Our team first discovered Asyncshell back in January 2024, when we found a malicious sample exploiting the CVE-2023–38831 vulnerability, with the overall attack chain shown below:



12. Finally, the as mentioned by the analysis of the Intelligence team, the whole APT process occurs from custom tools designed to upload stolen data to threat actor's servers which was C2 Communication server. According to MITRE ATT&CK Framework, the id for 'Exfiltration Over C2 Channel' is 'T1041'.

@VarmaOfficialRepo

T1048	Exfiltration Over Alternative Protocol	Adversaries may steal data by exfiltrating it over a different protocol than that of the existing command and control channel. The data may also be sent to an alternate network location from the main command and control server.
.001	Exfiltration Over Symmetric Encrypted Non-C2 Protocol	Adversaries may steal data by exfiltrating it over a symmetrically encrypted network protocol other than that of the existing command and control channel. The data may also be sent to an alternate network location from the main command and control server.
.002	Exfiltration Over Asymmetric Encrypted Non-C2 Protocol	Adversaries may steal data by exfiltrating it over an asymmetrically encrypted network protocol other than that of the existing command and control channel. The data may also be sent to an alternate network location from the main command and control server.
.003	Exfiltration Over Unencrypted Non-C2 Protocol	Adversaries may steal data by exfiltrating it over an un-encrypted network protocol other than that of the existing command and control channel. The data may also be sent to an alternate network location from the main command and control server.
T1041	Exfiltration Over C2 Channel	Adversaries may steal data by exfiltrating it over an existing command and control channel. Stolen data is encoded into the normal communications channel using the same protocol as command and control communications.

@VarmaOfficialRepo